

IoT Device Security Assessment

Testing OWASP IoTGoat v1.0 · Kali Linux · May 2026

14

Findings

4

Critical

5

High

5

Med/Low

AGENDA

01

Project Overview

What the CA asked and how I approached it

02

Lab Setup

OWASP IoTGoat on VMware with Kali Linux

03

Methodology

The 5-phase penetration testing process

04

Key Findings

The most critical vulnerabilities discovered

05

Risk Assessment

Rating each finding by likelihood and impact

06

Recommendations

How to fix the issues found

PROJECT OVERVIEW

CA Brief:

"IoT devices are deployed across the organisation. You must assess device security, identify weak configurations, and evaluate exposure risks."

01

Assess Device Security

Test IoT devices for known vulnerabilities using standard tools

02

Identify Weak Configurations

Find default credentials, open ports and insecure protocols

03

Evaluate Exposure Risks

Rate how dangerous each finding is to the organisation

LAB SETUP

ATTACKER MACHINE

OS

Kali Linux 2026

IP Address

192.168.57.129

Network

VMware Host-Only

Role

Penetration Tester

HOST-ONLY
NETWORK

TARGET DEVICE

Device

OWASP IoTGoat v1.0

IP Address

192.168.57.128

Firmware

OpenWrt (2019)

Purpose

Vulnerable IoT Lab

METHODOLOGY — 5 PHASE APPROACH

1

Reconnaissance

Discovered all devices on the network

```
nmap -sn 192.168.57.0/24
```

2

Enumeration

Found 6 open ports with service details

```
nmap -sV -sC -p- 192.168.57.128
```

3

Vulnerability Scan

Identified web and config weaknesses

```
nikto -h https://192.168.57.128
```

4

Exploitation

Confirmed findings with proof of concept

```
nc 192.168.57.128 5515
```

5

Reporting

Documented all findings with fixes

```
Full written report
```

NMAP SCAN RESULTS

Command: `nmap -sV -sC -p- 192.168.57.128`

22/TCP	SSH	Dropbear sshd	Medium
53/TCP	DNS	dnsmasq 2.73 (outdated)	High
80/TCP	HTTP	LuCI web config panel	High
443/TCP	HTTPS	LuCI with self-signed cert	Medium
5515/TCP	BACKDOOR	[***] IoTGoat Backdoor [***]	Critical
65534/TCP	Telnet	BusyBox telnetd	Critical

CRITICAL FINDINGS

F-001 — Backdoor on Port 5515

Connected with nc — got root shell instantly with no password

```
nc 192.168.57.128 5515
id → uid=0(root)
```

F-003 — Weak MD5 Password Hashes

Read /etc/shadow — both root and user hashes use broken MD5 (\$1\$)

```
cat /etc/shadow
```

F-002 — Telnet on Port 65534

Telnet sends all data including passwords as plain text over the network

```
telnet 192.168.57.128 65534
```

F-004 — WiFi — No Encryption

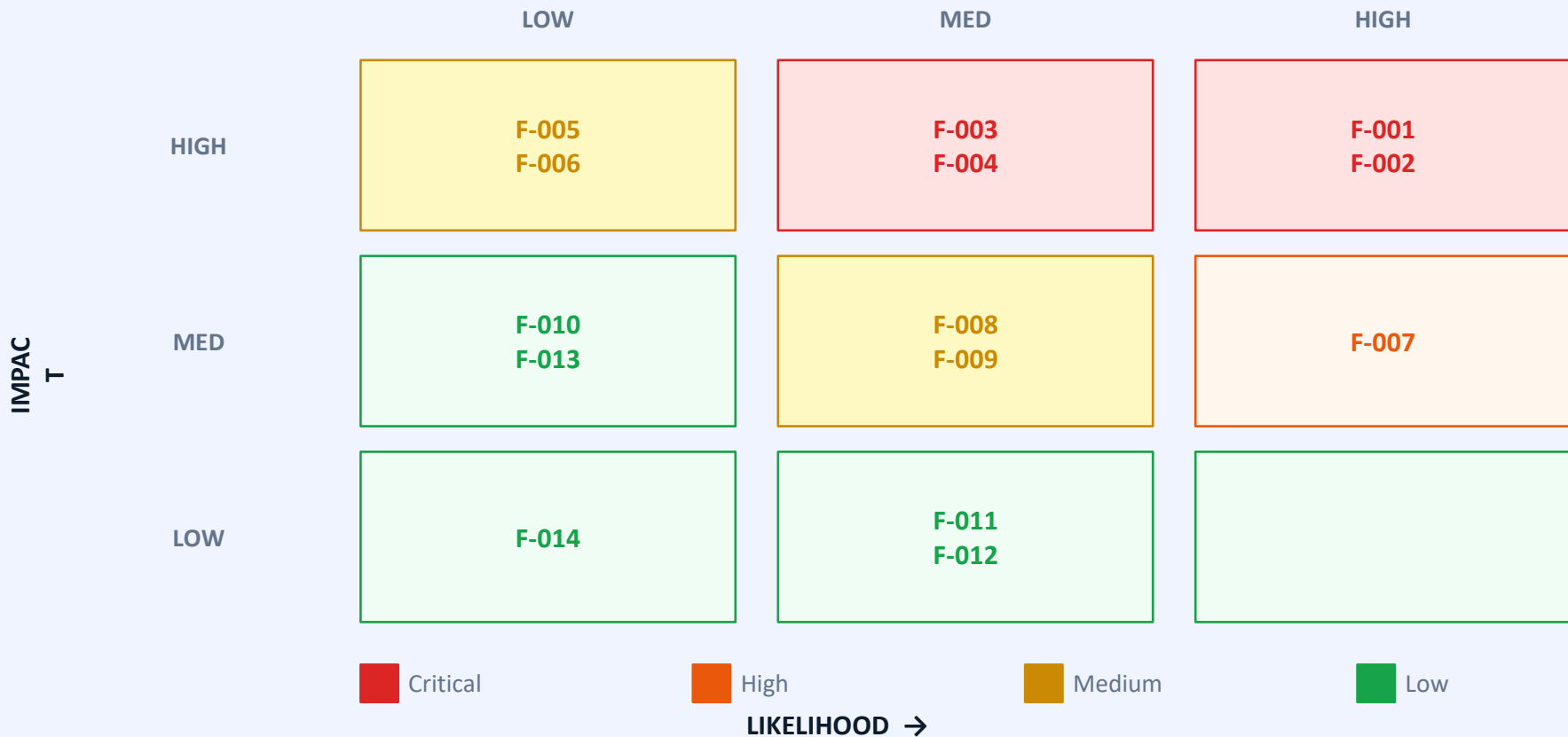
Wireless config shows encryption set to none. Anyone nearby can connect

```
/etc/config/wireless
```

OTHER FINDINGS

F-005	Linux Kernel from 2019	Over 7 years old — hundreds of known CVEs unpatched	
F-006	dnsmasq 2.73 Outdated	Old DNS service with known remote vulnerabilities	
F-007	Backup Config Files on Device	Network backup files readable by any attacker with shell access	
F-008	Missing X-Frame-Options	Web admin panel vulnerable to clickjacking attacks	
F-009	No HSTS Header	HTTPS can be downgraded to plain HTTP by attacker	
F-010	Self-Signed Certificate	Browser warns users, no trusted identity verification	
F-011	Certificate Hostname Mismatch	Certificate name does not match device IP address	
F-012	Missing Security Headers	X-Content-Type-Options not set — MIME sniffing risk	
F-013	ETag Inode Leakage	CVE-2003-1418: server exposes internal filesystem info	
F-014	Duplicate Shadow Entry	dnsmasq appears twice in /etc/shadow — misconfiguration	

RISK ASSESSMENT MATRIX



RECOMMENDATIONS

Immediate

Remove backdoor on port 5515 and replace firmware with a clean version

Immediate

Disable Telnet — use SSH with key-based authentication only

Immediate

Change password hashing from MD5 to SHA-512 on all accounts

Immediate

Enable WPA3 encryption on the WiFi access point

Short-term

Update device firmware to get a patched kernel and newer dnsmasq

Short-term

Add security headers: X-Frame-Options, HSTS, X-Content-Type-Options

Medium-term

Replace self-signed SSL certificate with one from a trusted authority

Medium-term

Remove backup config files from production devices

CONCLUSION

4 Critical vulnerabilities found — device not safe to deploy as-is

Most serious: unauthenticated backdoor giving instant root access

Old kernel (2019) and dnsmasq show firmware was never updated

All 14 findings documented with evidence, risk rating, and fixes

Immediate actions: remove backdoor, disable Telnet, enable WiFi encryption

Thank you · Questions?